Guide pratique SMSI (ISO/IEC 27001:2022)

Exercices, cas pratiques et méthodes pour devenir Lead Implementer opérationnel

Version 1.0 — 13/08/2025

Ce document propose une feuille de route, des exercices guidés, des cas pratiques et des gabarits prêts à l'emploi pour mettre en place un SMSI conforme à l'ISO/IEC 27001:2022.

Note: Ce guide est pédagogique et ne remplace pas la lecture des normes ISO applicables (27001, 27002, 27005, 27003, 27007). Adaptez toujours les exemples à votre contexte.

Feuille de route d'implémentation (vue macro)

- Engagement de la direction, désignation du sponsor, charte de projet et gouvernance (comités, rôles, RACI).
- Compréhension du contexte et des parties intéressées; exigences légales, réglementaires et contractuelles.
- Définition du périmètre du SMSI et des frontières: sites, systèmes, processus, exclusions justifiées.
- Politique de sécurité de l'information et objectifs mesurables (KPI/OKR).
- Inventaire des actifs informationnels, classification et propriétaires.
- Méthode d'appréciation du risque (ISO 27005/EBIOS RM), critères d'acceptation et matrice d'impact/probabilité.
- Appréciation des risques, plan de traitement, coûts, priorités et échéances.
- Déclaration d'Applicabilité (SoA) alignée sur l'Annexe A (93 contrôles de l'édition 2022).
- Mise en œuvre des contrôles, politiques, procédures et enregistrements requis.
- Sensibilisation et formation; gestion du changement, communication et conduite du projet.
- Surveillance et mesure: indicateurs, journaux, tableaux de bord, tests, audits internes.
- Revue de direction, actions correctives, amélioration continue (PDCA) et préparation à la certification.

Jeu d'exercices progressif (livrables attendus)

Exercice 1 — Contexte et parties intéressées

Objectifs

- Analyser le contexte interne/externe et identifier les parties intéressées et leurs attentes.
- Lister les exigences applicables (légales, réglementaires, contractuelles).

Consignes

- Réaliser une analyse SWOT et (optionnel) PESTEL sur l'organisation choisie (réelle ou fictive).
- Dresser la liste des parties intéressées et de leurs exigences pertinentes.

Livrables

- Note de contexte (1-2 pages).
- Registre des parties intéressées et exigences associées.

Exercice 2 — Périmètre du SMSI

Objectifs

- Définir un périmètre clair et justifier les exclusions.
- Identifier les processus, sites, systèmes et services couverts.

Consignes

- Rédiger un énoncé de périmètre incluant frontières, interfaces, dépendances et hypothèses.
- Valider le périmètre avec la direction (simulation de validation).

Livrables

- Énoncé de périmètre (scope statement) prêt à approuver.

Exercice 3 — Inventaire et classification des actifs

Objectifs

- Établir un inventaire structuré des actifs informationnels.
- Attribuer des propriétaires et une classification (ex: Public, Interne, Confidentiel).

Consignes

- Lister actifs: informations, applications, matériels, services, personnes, fournisseurs.
- Associer criticité et impacts (disponibilité, intégrité, confidentialité).

Livrables

- Registre des actifs avec classification et propriétaire.

Exercice 4 — Critères d'acceptation et matrice de cotation

Objectifs

- Définir les niveaux d'impact et de probabilité, et le seuil d'acceptation du risque.

Consignes

- Construire une grille 1-5 pour Impact et Probabilité (adaptée à votre contexte).
- Définir les bandes de risque (faible, moyen, élevé).

Livrables

- Politique de gestion des risques (critères et matrice).

Exercice 5 — Appréciation des risques (ISO 27005 / EBIOS RM)

Objectifs

- Identifier menaces et vulnérabilités, évaluer risques et prioriser.

Consignes

- Sélectionner 5 scénarios de risque significatifs et calculer le niveau de risque initial.
- Proposer des options de traitement (réduire, éviter, transférer, accepter).

Livrables

- Registre des risques avec calculs et priorités.

Exercice 6 — Plan de traitement des risques (PTR)

Objectifs

- Définir les mesures, les responsables, les budgets, les délais et les dépendances.

Consignes

- Établir un PTR sur 3-6 mois avec jalons, coûts et bénéfices.
- Préparer une présentation de validation pour le comité de pilotage.

Livrables

- PTR validé et calendrier de déploiement.

Exercice 7 — Déclaration d'Applicabilité (SoA)

Objectifs

- Documenter l'applicabilité des 93 contrôles de l'Annexe A et leur statut.

Consignes

- Justifier inclusion/exclusion pour chaque contrôle et référencer la documentation associée.

Livrables

- SoA versionnée et approuvée.

Exercice 8 — Politiques et procédures clés

Objectifs

- Produire les politiques minimales et 3-5 procédures critiques.

Consignes

- Rédiger: Politique de SI, Politique de classification, Politique contrôle d'accès.
- Rédiger 3-5 procédures: gestion incidents, sauvegardes, gestion changements, gestion logs, MDM.

Livrables

- Corpus documentaire versionné, contrôlé et diffusé.

Exercice 9 — Sensibilisation et formation

Objectifs

- Structurer un programme de sensibilisation sur 12 mois.

Consignes

- Planifier campagnes, supports, évaluations et suivi du taux de complétion.

Livrables

- Programme annuel, contenus et indicateurs (ex: taux de réussite > 85%).

Exercice 10 — KPI et tableaux de bord

Objectifs

- Définir des objectifs mesurables et les instruments de mesure.

Consignes

- Sélectionner 8-12 indicateurs (ex: MTTR incidents, patching SLA, pourcentage comptes avec MFA).

Livrables

- Tableau de bord mensuel du SMSI (visuel simple).

Exercice 11 — Programme d'audit interne

Objectifs

- Planifier un programme couvrant clauses 4-10 et Annexe A sur 12 mois.

Consignes

- Construire des checklists, critères, périmètres et méthodes d'échantillonnage.

Livrables

- Programme d'audit, checklists, rapports et suivi d'actions.

Exercice 12 — Revue de direction et préparation certification

Objectifs

- Consolider l'état du SMSI et préparer l'audit externe.

Consignes

- Collecter preuves, indicateurs, résultats d'audits, NC et actions, décisions SoA.

Livrables

- Dossier de revue de direction, registre d'actions et plan de remédiation.

Exemples de grilles et gabarits

Matrice de cotation (exemple)

Critère	1	2	3	4	5
Impact (CIA)	Mineur	Modéré	Significatif	Majeur	Critique
Probabilité	Très rare	Peu probable	Possible	Probable	Très probable
Tolérance	Acceptable	Acceptable	Surveiller	Réduire	Réduire/Avoid

Gabarit de registre des risques (exemple de colonnes)

io de risque	Menaces/Vulnérabilités	Impact	Prob.	Niveau initial	Option traitement	Contrôles (Annexe A)	Niveau résid

Gabarit de Déclaration d'Applicabilité (SoA) — colonnes clés

Intitulé (Annexe A)	Applicable ?	Justification	Statut	Références (polis/

Cas pratiques (scénarios types)

PME SaaS B2B (Cloud, multi-tenant)

Contexte

- Application SaaS exposée sur Internet, clients entreprises, exigences contractuelles fortes.
- Environnement cloud (IaaS/PaaS), intégration CI/CD et déploiements fréquents.

Périmètre

- Services applicatifs, données clients, pipeline CI/CD, gestion des secrets, fournisseurs cloud.

Principaux scénarios de risque

- Exfiltration de données clients suite à vulnérabilité applicative (OWASP Top 10).
- Compromission d'identifiants et mouvements latéraux via accès à privilèges.
- Indisponibilité majeure due à défaillance configuration cloud (erreur humaine).

Contrôles phares (Annexe A 2022)

- Gestion des identités et des accès, MFA, moindres privilèges, séparation des environnements.
- Durcissement du pipeline CI/CD, revue de code, tests SAST/DAST, gestion des secrets.
- Journalisation, détection d'incidents, sauvegardes et plans de reprise.

KPI recommandés

- Taux de couverture MFA > 98% des comptes.
- Délai moyen de correction vulnérabilités critiques < 7 jours.
- Taux de conformité des sauvegardes restaurées > 99%.

Livrables attendus

- SoA spécifique au cloud, politiques d'accès, procédure de gestion des vulnérabilités, PTR priorisé.

Clinique / Hôpital (données de santé)

Contexte

- Forte contrainte réglementaire (données de santé, secret médical), disponibilité critique.
- Parc hétérogène (SIH, imagerie, biomédical), nombreux sous-traitants.

Périmètre

- SIH, dossiers patients, imagerie, réseau médical, prestataires et hébergement HDS (si applicable).

Principaux scénarios de risque

- Ransomware impactant patients et continuité de soins.
- Fuite d'imagerie médicale via partages mal configurés.
- Interruption d'un service critique par panne et absence de PRA testé.

Contrôles phares (Annexe A 2022)

- Segmentation réseau, durcissement postes biomédicaux, sauvegardes 3-2-1 et PRA testé.
- Gestion des prestataires, clauses contractuelles, journalisation réglementaire.
- Sensibilisation ciblée phishing et hygiène numérique.

KPI recommandés

- Taux de disponibilité services critiques > 99,9%.
- Délai rétablissement (RTO) respecté lors des tests PRA.
- Taux de non-conformités fournisseurs résolues < 30 jours.

Livrables attendus

- Cartographie applicative critique, plan de continuité, dossiers d'homologation, programme d'audit fournisseurs.

Fintech / Services financiers

Contexte

- Exigences réglementaires et d'audit élevées, tolérance au risque très faible.
- Forte exposition fraude et conformité (KYC/AML en périphérie).

Périmètre

- Systèmes de paiement, bases clients, anti-fraude, partenaires bancaires et PSP.

Principaux scénarios de risque

- Fraude par prise de contrôle de compte, injection de transactions non autorisées.
- Risque tiers sur PSP/sous-traitants critiques.

Contrôles phares (Annexe A 2022)

- Contrôles d'accès renforcés, séparation des tâches, surveillance transactions, alertes en temps réel.
- Due diligence fournisseurs, tests de reprise, chiffrement en transit/au repos.

KPI recommandés

- Taux d'alertes traitées < 15 min; faux positifs < 5%.
- Audit logs conservés 12-24 mois, intègres et exploitables.

Livrables attendus

- Politique d'acceptation des risques, SoA complète, procédures anti-fraude et de journalisation.

Méthodes et pratiques recommandées

- PDCA (Plan-Do-Check-Act): coeur de l'amélioration continue du SMSI.
- Gestion des risques (ISO 27005, EBIOS RM): registre des risques vivant, seuils d'acceptation, revues périodiques.
- Gestion documentaire: contrôle des versions, statuts, propriétaires et périodicité de revue.
- Gestion des accès: principes de moindre privilège, MFA, revue périodique des droits.
- Gestion des changements: évaluation d'impacts sécurité, approbations et traçabilité.
- Gestion des incidents: détection, enregistrement, classification, réponse, post-mortem et leçons apprises.
- Continuité d'activité: analyses d'impact (BIA), stratégies, PRA/PCA, tests réguliers.
- Sécurité des fournisseurs: due diligence, clauses contractuelles, revues et indicateurs.
- Sécurité des développements: revue de code, SAST/DAST, gestion des dépendances, secrets, SBOM.
- Protection des données à caractère personnel: principes, registre des traitements, minimisation, DPIA si nécessaire.

Contrôles ISO/IEC 27001:2022 — thématiques (93 contrôles)

Organisationnel, Humain, Physique, Technologique. Cartographiez vos contrôles internes à ces thématiques et référencez-les dans la SoA.

Annexes et gabarits

Gabarit — Énoncé de périmètre (exemple)

Le SMSI couvre: [sites, unités, processus, systèmes]. Interfaces: [internes/externes]. Exclusions: [justifiées]. Hypothèses: [liste]. Périmètre temporel: [date].

Gabarit — Politique de sécurité (sections minimales)

- Objet et champ d'application
- Engagement de la direction
- Rôles et responsabilités
- Approche de gestion des risques
- Objectifs et mesures de performance
- Gestion documentaire et diffusion
- Conformité et sanctions

Checklist — Clauses 4 à 10 (exemples de questions)

- Clause 4 (Contexte): Le périmètre et les parties intéressées sont-ils documentés et à jour?
- Clause 5 (Leadership): La politique est-elle communiquée et comprise?
- Clause 6 (Planification): Les risques et opportunités sont-ils traités? Critères définis?
- Clause 7 (Support): Ressources, compétences et sensibilisation sont-elles démontrées?
- Clause 8 (Opérations): Procédures mises en oeuvre et traces conservées?
- Clause 9 (Évaluation): Indicateurs, audits internes et revue de direction réalisés?
- Clause 10 (Amélioration): NC traitées dans les délais, leçons apprises capitalisées?

Liens utiles (références publiques)

ANSSI — EBIOS Risk Manager

NIST — Publications (ex: SP 800-61, SP 800-53)

OWASP Top 10

CIS Critical Security Controls

CSA Cloud Controls Matrix

Mentions: Les marques et normes citées appartiennent à leurs propriétaires respectifs. Document éducatif.